

What are the main types of cybersecurity threats?

The main types of information security threats are:

- ☐ Malware attack
- ☐ Social engineering attacks
- ☐ Software supply chain attacks
- ☐ Advanced persistent threats (APT)
- ☐ Distributed denial of service (DDoS)
- ☐ Man-in-the-middle attack (MitM)
- ☐ Password attacks

1. Malware attack

Attacks use many methods to get malware into a user's device, most often social engineering. Users may be asked to take an action, such as clicking a link or opening an attachment. In other cases, malware uses vulnerabilities in browsers or operating systems to install themselves without the user's knowledge or consent.

Once malware is installed, it can monitor user activities, send confidential data to the attacker, assist the attacker in penetrating other targets within the network, and even cause the user's device to participate in a botnet leveraged by the attacker for malicious intent.

Malware attacks include:

- ☐ Trojan virus — tricks a user into thinking it is a harmless file. A Trojan can launch an attack on a system and can establish a backdoor, which attackers can use.
- ☐ Ransomware — prevents access to the data of the victim and threatens to delete or publish it unless a ransom is paid. Learn more in our guide to ransomware prevention.
- ☐ Wiper malware — intends to destroy data or systems, by overwriting targeted files or destroying an entire file system. Wipers are usually

intended to send a political message, or hide hacker activities after data exfiltration.

🔗 Worms — this malware is designed to exploit backdoors and vulnerabilities to gain unauthorized access to operating systems. After installation, the worm can perform various attacks, including Distributed Denial of Service (DDoS).

🔗 Spyware — this malware enables malicious actors to gain unauthorized access to data, including sensitive information like payment details and credentials. Spyware can affect mobile phones, desktop applications, and desktop browsers.

🔗 Fileless malware — this type of malware does not require installing software on the operating system. It makes native files such as PowerShell and WMI editable to enable malicious functions, making them recognized as legitimate and difficult to detect.

🔗 Application or website manipulation — OWASP outlines the top 10 application security risks, ranging from broken access controls and security misconfiguration through injection attacks and cryptographic failures. Once the vector is established through service account acquisition, more malware, credential, or APT attacks are launched.

2. Social engineering attacks

Social engineering attacks work by psychologically manipulating users into performing actions desirable to an attacker, or divulging sensitive information.

Social engineering attacks include:

🔗 Phishing — attackers send fraudulent correspondence that seems to come from legitimate sources, usually via email. The email may urge the user to perform an important action or click on a link to a malicious website, leading them to hand over sensitive information to the attacker, or expose themselves to malicious downloads. Phishing

emails may include an email attachment infected with malware.

🔗 Spear phishing — a variant of phishing in which attackers specifically target individuals with security privileges or influence, such as system administrators or senior executives.

🔗 Malvertising — online advertising controlled by hackers, which contains malicious code that infects a user's computer when they click, or even just view the ad. Malvertising has been found on many leading online publications.

🔗 Drive-by downloads — attackers can hack websites and insert malicious scripts into PHP or HTTP code on a page. When users visit the page, malware is directly installed on their computer; or, the attacker's script redirects users to a malicious site, which performs the download. Drive-by downloads rely on vulnerabilities in browsers or operating systems. Learn more in the guide to drive-by downloads.

🔗 Scareware security software — pretends to scan for malware and then regularly shows the user fake warnings and detections. Attackers may ask the user to pay to remove the fake threats from their computer or to register the software. Users who comply transfer their financial details to an attacker.

🔗 Baiting — occurs when a threat actor tricks a target into using a malicious device, placing a malware-infected physical device, like a USB, where the target can find it. Once the target inserts the device into their computer, they unintentionally install the malware.

🔗 Vishing — voice phishing (vishing) attacks use social engineering techniques to get targets to divulge financial or personal information over the phone.

🔗 Whaling — this phishing attack targets high-profile employees (whales), such as the chief executive officer (CEO) or chief financial

officer (CFO). The threat actor attempts to trick the target into disclosing confidential information.

❑ Pretexting — occurs when a threat actor lies to the target to gain access to privileged data. A pretexting scam may involve a threat actor pretending to confirm the target's identity by asking for financial or personal data.

❑ Scareware — a threat actor tricks the victim into thinking they inadvertently downloaded illegal content or that their computer is infected with malware. Next, the threat actor offers the victim a solution to fix the fake problem, tricking the victim into downloading and installing malware.

❑ Diversion theft — threat actors use social engineers to trick a courier or delivery company into going to a wrong drop-off or pickup location, intercepting the transaction.

❑ Honey trap — a social engineer assumes a fake identity as an attractive person to interact with a target online. The social engineer fakes an online relationship and gathers sensitive information through this relationship.

❑ Tailgating or piggybacking — occurs when a threat actor enters a secured building by following authorized personnel. Typically, the staff with legitimate access assumes the person behind is allowed entrance, holding the door open for them.

❑ Pharming — an online fraud scheme during which a cybercriminal installs malicious code on a server or computer. The code automatically directs users to a fake website, where users are tricked into providing personal data.

3. Software supply chain attacks

A software supply chain attack is a cyber attack against an organization that

targets weak links in its trusted software update and supply chain. A supply chain is the network of all individuals, organizations, resources, activities, and technologies involved in the creation and sale of a product. A software supply chain attack exploits the trust that organizations have in their third-party vendors, particularly in updates and patching.

This is especially true for network monitoring tools, industrial control systems, “smart” machines, and other network-enabled systems with service

accounts. An attack can be made in many places against the vendor continuous integration and continuous delivery (CI/CD) software lifecycle, or even against third-party libraries and components as seen via Apache and Spring.

Types of software supply chain attacks:

- ❑ Compromise of software build tools or dev/test infrastructure
- ❑ Compromise of devices or accounts owned by privileged third-party vendors
- ❑ Malicious apps signed with stolen code signing certificates or developer IDs
- ❑ Malicious code deployed on hardware or firmware components
- ❑ Malware pre-installed on devices such as cameras, USBs, and mobile phones
- ❑

4. Advanced persistent threats (APT)

When an individual or group gains unauthorized access to a network and remains undiscovered for an extended period of time, attackers may exfiltrate sensitive data, deliberately avoiding detection by the organization’s security staff. APTs require sophisticated attackers and involve major efforts, so they are typically launched against nation states, large corporations, or other highly valuable targets.

Common indicators of an APT presence include:

- ❑ New account creation — the P in Persistent comes from an attacker creating an identity or credential on the network with elevated privileges.
- ❑ Abnormal activity — legitimate user accounts typically perform in patterns. Abnormal activity on these accounts can indicate an APT is occurring, including noting a stale account which was created then left unused for a time suddenly being active.
- ❑ Backdoor/trojan horse malware — extensive use of this method enables APTs to maintain long-term access.
- ❑ Odd database activity — for example, a sudden increase in database operations with massive amounts of data.
- ❑ Unusual data files — the presence of these files can indicate data has been bundled into files to assist in an exfiltration process.

5. Distributed denial of service (DDoS)

The objective of a denial of service (DoS) attack is to overwhelm the resources of a target system and cause it to stop functioning, denying access to its users. Distributed denial of service (DDoS) is a variant of DoS in which attackers compromise a large number of computers or other devices, and use them in a coordinated attack against the target system. DDoS attacks are often used in combination with other cyberthreats. These attacks may launch a denial of service to capture the attention of security staff and create confusion, while they carry out more subtle attacks aimed at stealing data or causing other damage.

Methods of DDoS attacks include:

- ❑ Botnets — systems under hacker control that have been infected with malware. Attackers use these bots to carry out DDoS attacks. Large

botnets can include millions of devices and can launch attacks at devastating scale.

❑ Smurf attack — sends Internet Control Message Protocol (ICMP) echo requests to the victim's IP address. The ICMP requests are generated from 'spoofed' IP addresses. Attackers automate this process and perform it at scale to overwhelm a target system.

❑ TCP SYN flood attack — attacks flood the target system with connection requests. When the target system attempts to complete the connection, the attacker's device does not respond, forcing the target system to time out. This quickly fills the connection queue, preventing legitimate users from connecting.

6. Man-in-the-middle attack (MitM)

When users or devices access a remote system over the internet, they assume they are communicating directly with the server of the target system.

In a MitM attack, attackers break this assumption, placing themselves in between the user and the target server.

Once the attacker has intercepted communications, they may be able to compromise a user's credentials, steal sensitive data, and return different responses to the user.

MitM attacks include:

❑ Session hijacking — an attacker hijacks a session between a network server and a client. The attacking computer substitutes its IP address for the IP address of the client. The server believes it is corresponding with the client and continues the session.

❑ Replay attack — a cybercriminal eavesdrops on network communication and replays messages at a later time, pretending to be the user. Replay attacks have been largely mitigated by adding timestamps to network communications.

❑ IP spoofing — an attacker convinces a system that it is corresponding with a trusted, known entity. The system thus provides the attacker with access. The attacker forges its packet with the IP source address of a trusted host, rather than its own IP address.

❑ Eavesdropping attack — attackers leverage insecure network communication to access information transmitted between the client and server. These attacks are difficult to detect because network transmissions appear to act normally.

❑ Bluetooth attacks — Because Bluetooth is often open in promiscuous mode, there are many attacks, particularly against phones, that drop contact cards and other malware through open and receiving Bluetooth connections. Usually this compromise of an endpoint is a means to an end, from harvesting credentials to personal information.

7. Password attacks

A hacker can gain access to the password information of an individual by ‘sniffing’ the connection to the network, using social engineering, guessing,

or gaining access to a password database. An attacker can ‘guess’ a password in a random or systematic way.

Password attacks include:

❑ Brute-force password guessing — an attacker uses software to try many different passwords, in hopes of guessing the correct one. The software can use some logic to trying passwords related to the name of the individual, their job, their family, etc.

❑ Dictionary attack — a dictionary of common passwords is used to gain access to the computer and network of the victim. One method is to copy an encrypted file that has the passwords, apply the same encryption to a dictionary of regularly used passwords, and contrast the findings.

❑ Pass-the-hash attack — an attacker exploits the authentication protocol in a session and captures a password hash (as opposed to the password characters directly) and then passes it through for authentication and lateral access to other networked systems. In these attack types, the threat actor doesn't need to decrypt the hash to obtain a plain text password.

❑ Golden ticket attack — a golden ticket attack starts in the same way as a pass-the-hash attack, where on a Kerberos (Windows AD) system the attacker uses the stolen password hash to access the key distribution center to forge a ticket-granting-ticket (TGT) hash. Mimikatz attacks frequently use this attack vector.

Cyberthreat actors

When you identify a cyberthreat, it's important to understand who the threat actor is, as well as their tactics, techniques, and procedures (TTP). Common sources of cyberthreats include:

❑ State-sponsored — cyberattacks by countries can disrupt communications, military activities, or other services that citizens use daily.

❑ Terrorists — terrorists may attack government or military targets, but at times may also target civilian websites to disrupt and cause lasting damage.

❑ Industrial spies — organized crime and international corporate spies carry out industrial espionage and monetary theft. Their primary motive is financial.

❑ Organized crime groups — criminal groups infiltrate systems for monetary gain. Organized crime groups use phishing, spam, and malware to carry out identity theft and online fraud. There are organized crime groups who exist to sell hacking services to others as

well, maintaining even support and services for profiteers and industrial spies alike.

🔗 Hackers — there is a large global population of hackers, ranging from beginner “script kiddies” or those leveraging ready-made threat toolkits, to sophisticated operators who can develop new types of threats and avoid organizational defenses.

🔗 Hacktivists — hacktivists are hackers who penetrate or disrupt systems for political or ideological reasons rather than financial gain.

🔗 Malicious insider — insiders represent a very serious threat, as they have existing access to corporate systems and knowledge of target systems and sensitive data. Insider threats can be devastating and very difficult to detect.

🔗 Cyber espionage — is a form of cyberattack that steals classified, or sensitive intellectual data to gain an advantage over a competitive company or government entity.

Emerging information security threats and challenges in 2023

As technology evolves, so do the threats and issues that security teams face. Below are a few of the top trends and concerns in cybersecurity today.

Use of artificial intelligence (AI) by attackers

AI is a double-edged sword; it is improving security solutions but at the same time is leveraged by attackers to bypass those solutions. Part of the reason

for this is the growing accessibility to AI. In the past, developing machine learning models was only possible if you had access to significant budgets and resources. Now, however, models can be developed on personal laptops.

This accessibility makes AI a tool that has expanded from major digital arms races to everyday attacks. While security teams are using AI to try to detect

suspicious behavior, criminals are using it to make bots that pass for human users and to dynamically change the characteristics and behaviors of malware.

Cybersecurity skills gap

There is a constant concern over the cybersecurity skills gap. There are simply not enough cybersecurity experts to fill all of the positions needed. As more companies are created and others update their existing security strategies, this number increases.

Modern threats, from cloned identities to deep fake campaigns, are getting harder to detect and stop. The security skills required to combat these threats go far beyond just understanding how to implement tools or configure encryptions. These threats require diverse knowledge of a wide variety of technologies, configurations, and environments. To obtain these skills, organizations must recruit high-level experts or dedicate the resources to training their own.

Vehicle hacking and Internet of Things (IoT) threats

The amount of data contained in a modern vehicle is huge. Even cars that are not autonomous are loaded with a variety of smart sensors. This includes GPS devices, built-in communications platforms, cameras, and AI controllers. Many people's homes, workplaces, and communities are full of similar smart devices. For example, personal assistants embedded in speakers are smart devices.

The data on these devices can provide sensitive information to criminals. This information includes private conversations, sensitive images, tracking information, and access to any accounts used with devices. These devices can be easily leveraged by attackers for blackmail or personal gain. For example, abusing financial information or selling information on the black market.

With vehicles in particular, the threat of personal harm is also very real.

When vehicles are partially or entirely controlled by computers, attackers have the opportunity to hack vehicles just like any other device. This could enable them to use vehicles as weapons against others or as a means to harm the driver or passengers.

Threats facing mobile devices

Even if people haven't fully embraced smart technologies, nearly everyone has a mobile device of some sort. Smartphones, laptops, and tablets are common. These devices are often multipurpose, used for both work and personal activities, and users may connect devices to multiple networks throughout the day.

This abundance and widespread use make mobile devices an appealing target for attackers. Targeting is not new but the real challenge comes from security teams not having full control over devices. Bring your own device (BYOD) policies are common but these policies often do not include internal control or management.

Often, security teams are only able to control what happens with these devices within the network perimeter. Devices may be out of date, already infected with malware, or have insufficient protections. The only way security teams may have to block these threats is to refuse connectivity, which isn't practical.

Cloud security threats

With businesses moving to cloud resources daily, many environments are growing more complex. This is particularly true in the case of hybrid and multi-cloud environments, which require extensive monitoring and integration.

With every cloud service and resource that is included in an environment, the number of endpoints and the chances for misconfiguration increase.

Additionally, since resources are in the cloud, most, if not all endpoints are Internet-facing, granting access to attackers on a global scale.

To secure these environments, cybersecurity teams need advanced, centralized tooling and often more resources. This includes resources for 24/7 protection and monitoring since resources are running and potentially vulnerable even when the workday is over.

State-sponsored attacks

The Russia-Ukraine war and the new geopolitical situation has raised the stakes of state-sponsored attacks against Western nations and organizations. As more of the world moves to the digital realm, the number of large-scale and state-sponsored attacks are increasing. Networks of hackers can now be leveraged and bought by opposing nation-states and interest groups to cripple governmental and organizational systems.

For some of these attacks, the results are readily apparent. For example, numerous attacks have been identified that involved tampering with elections. Others, however, may go unnoticed, silently gathering sensitive information, such as military strategies or business intelligence. In either case, the resources funding these attacks enables criminals to use advanced and distributed strategies that are difficult to detect and prevent.

Using threat intelligence for threat prevention

Threat intelligence is organized, pre-analyzed information about attacks that may threaten an organization. Threat intelligence helps organizations understand potential or current cyberthreats. The more information security

staff have about threat actors, their capabilities, infrastructure, and motives, the better they can defend their organization.

Threat intelligence systems are commonly used in combination with other security tools. When a security system identifies a threat, it can be cross-

referenced with threat intelligence data to immediately understand the nature of the threat, its severity, and known methods for mitigating or containing the threat. In many cases, threat intelligence can help automatically block threats — for example, known bad IP addresses can be fed to a firewall, to automatically block traffic from compromised servers.

Threat intelligence is typically provided in the form of feeds. There are free threat intelligence feeds, and others provided by commercial security research bodies. Several vendors provide threat intelligence platforms that come with numerous threat intelligence feeds and help manage threat data and integrate it with other security systems.

Using UEBA and SOAR to mitigate information security threats

User and Entity Behavior Analytics (UEBA) and Security Orchestration, Automation, and Response (SOAR) are technologies that aggregate threat activity data and automate processes related to its identification and analysis, increasing the effectiveness and efficiency of security teams.

UEBA

UEBA uses machine learning to construct a baseline of normal behavior for users or devices/entities within a network, which helps to detect deviations from the baseline behavior. Behavior models and machine learning assign various levels of risk depending on the type of behavior. The risk score of the user or device for an event is determined and is stitched with related events into a timeline to assess if these events pose a threat to an organization. By tying together the behaviors identified as anomalous, analysts can trace all the steps an attacker has taken and thus pin down the threat quickly.

Unlike SIEM, UEBA solutions can detect threat activity over an extended period across multiple organizational systems. UEBA allows security teams to work more efficiently by narrowing down the number of threats they need

to investigate, generating alerts, and providing information on breaches that occur.

UEBA can help identify a variety of insider threats, data exfiltration, and lateral movement:

❑ Malicious insiders — by determining a baseline of behavior for users, UEBA can detect abnormal activity and assist in interpreting intent. For example, a user might have genuine access privileges but not need to access sensitive data at a given time or place.

❑ Compromised insiders — users with access privileges can become compromised through malware or phishing attempts, allowing their credentials to be used to initiate an attack. Attackers often change credentials, IP addresses, or devices once in the system. By comparing device and user behavior to baselines, UEBA can identify these attacks in a way that traditional security tools like firewalls and antivirus cannot.

❑ Data exfiltration — tools like data loss prevention (DLP) that use machine learning, dictionary models, and behavior models to gather all evidence related to sensitive data exfiltration can quickly investigate and alert on anomalous activity. This includes data uploads, remote logins, database activities, cloud access, and file share access.

❑ Lateral movement — attackers often traverse a network using a variety of IP addresses, credentials, and machines in search of key assets and data. UEBA tools detect this movement by enriching data with context which allows them to distinguish between servers, users, service accounts, HR personnel, finance staff, and executives and determine if they are behaving suspiciously.

UEBA can also prioritize high-risk events and monitor large numbers of devices:

▣ Incident prioritization — can help determine which incidents are particularly suspicious or dangerous by evaluating them in the context of organizational structure and potential for damage.

▣ Monitoring large numbers of devices — can be used even when a baseline for normal behavior has not yet been developed, using heuristic methods like supervised machine learning, Bayesian networks, unsupervised learning, reinforced machine learning, and deep learning.

SOAR

SOAR tools collect data for security investigations from multiple sources, facilitate incident analysis and triage with machine assistance, define and direct threat response workflow, and enable automated incident response. Security teams can integrate SOAR tools with other security solutions to respond to incidents more effectively. They can use these solutions through a generic interface, eliminating the need for expert analysts specializing in each system. SOAR allows security teams to automate enforcement and status tracking or auditing tasks based on decision-making workflows as assigned.

SOAR tools simplify incident management and collaboration by automatically generating incidents based on guidelines and including relevant contextual information. They provide a timeline of events for analysis and allow for the addition of evidence as it is found as well as assisting case management by accepting documentation of threats, responses, and outcomes. A comprehensive UEBA solution goes hand-in-hand with SOAR as an effective investigation tool, where the ultimate goal of SOC analysts is to reduce the time needed to detect threats and respond to incidents.

Finally, SOAR tools aid security teams in effectively responding to security incidents by proactively enforcing processes to gather comprehensive evidence, seamlessly integrating with various third-party services and

security vendors, and associating a timeline of events to pinpoint anomalous behavior.